

Bilaga 2 – MCFFS 2026:12: Säkerhetsrevision och säkerhetsskanning

MCFFS 2026:12 reglerar hur säkerhetsrevisioner och säkerhetsskanningar enligt cybersäkerhetslagen (NIS2) ska genomföras.

Föreskriften träder i kraft den **1 oktober 2026**.

För verksamhetsutövare är föreskriften viktig eftersom den ger en tydligare bild av **hur faktisk efterlevnad kan komma att verifieras vid tillsyn**.

Observera: Detta är en sammanfattande vägledning och ersätter inte föreskriften eller juridisk bedömning av vilka krav som gäller för en specifik verksamhet.

Två olika tillsynsverktyg

Föreskriften behandlar två separata verktyg:

Säkerhetsrevision En granskning av om organisationens säkerhetsåtgärder och efterlevnad av cybersäkerhetslagen är ändamålsenliga och effektiva.

Säkerhetsskanning Teknisk skanning av system för att identifiera sårbarheter eller osäkra konfigurationer.

Skillnaden är viktig.

En säkerhetsrevision kan omfatta hela organisationens styrning och säkerhetsarbete, medan säkerhetsskanningen är ett mer tekniskt kontrollverktyg.

1. Säkerhetsrevision

Syftet med en säkerhetsrevision är att bedöma:

- organisationens cybersäkerhetsnivå,
- om säkerhetsåtgärderna uppfyller cybersäkerhetslagen och tillhörande reglering,
- om säkerhetsåtgärderna är ändamålsenliga,
- om säkerhetsåtgärderna faktiskt fungerar i praktiken.

Det innebär att en revision inte bara granskar **vad organisationen säger att den gör**, utan även **hur säkerhetsåtgärderna tillämpas**.

2. Oberoende revisor

När tillsynsmyndigheten anlitar ett oberoende organ för revisionen ska detta ha tillräcklig kompetens för uppdraget och vid behov även kunskap om den verksamhet som granskas.

Det oberoende organet ska bland annat kunna genomföra uppdraget:

- opartiskt,
- självständigt,
- objektivt.

Det ska också kunna hantera information från revisionen på ett säkert sätt.

Tillsynsmyndigheten bör undvika att anlita en aktör som exempelvis redan har rådgivningsuppdrag eller andra beroendeförhållanden till den organisation som granskas.

3. Vad kan en säkerhetsrevision innehålla?

MCFFS 2026:12 anger att en säkerhetsrevision åtminstone ska inkludera:

1. **granskning av dokumentation,**
2. **intervjuer med berörd personal,**
3. **tekniska kontroller av system och segment,**
4. **vid behov kontroll av lokaler.**

Intervjuer, tekniska kontroller och kontroll av lokaler ska normalt genomföras **på plats hos verksamhetsutövaren**, om inte särskilda skäl talar emot.

Det innebär att en NIS2-revision kan gå betydligt längre än en traditionell dokumentgranskning.

4. Både design och faktisk tillämpning granskas

En särskilt viktig formulering i föreskriften är att revisionen ska kontrollera både:

Utformning Är säkerhetsåtgärden korrekt designad?

och

Tillämpning Används säkerhetsåtgärden faktiskt på det sätt organisationen beskriver?

Det skapar ett tydligt behov av **evidens**.

En organisation kan exempelvis behöva kunna visa:

- konfigurationer,
 - loggar,
 - genomförda kontroller,
 - utbildningsregister,
 - riskanalyser,
 - behörighetsgranskningar,
 - revisionsresultat,
 - säkerhetstester,
 - leverantörsuppföljningar,
 - incidentövningar,
 - backup- och restore-tester.
-

5. Revisionen ska vara systematisk och riskbaserad

Säkerhetsrevisionen ska använda en dokumenterad metodik som möjliggör systematisk och riskbaserad granskning av:

- organisatoriska säkerhetsåtgärder,
- tekniska säkerhetsåtgärder,
- driftrelaterade säkerhetsåtgärder,
- fysiska säkerhetsåtgärder.

Föreskriften pekar bland annat ut etablerade standarder för revisionsmetodik såsom:

- ISO/IEC 17021-1,
- ISO/IEC 17020,
- ISO/IEC 27007,
- ISO/IEC 27006-1,
- ISAE 3000.

Det innebär inte automatiskt att organisationen måste vara certifierad enligt dessa standarder, utan de anges som stöd för revisionsmetodiken.

6. Avvikelser dokumenteras

Det oberoende revisionsorganet ska dokumentera avvikelser från cybersäkerhetslagen och tillhörande reglering.

Efter revisionen ska resultatet sammanställas i en **skriftlig rapport** och överlämnas till tillsynsmyndigheten.

Rapporten bör bland annat innehålla:

- identifierade sårbarheter,
 - annan relevant information från revisionen,
 - förslag på åtgärder.
-

7. Tekniska kontroller blir en del av tillsynen

En viktig konsekvens är att NIS2-tillsyn inte behöver begränsas till policies, processer och intervjuer.

Revisionen ska även omfatta **tekniska kontroller av system och nätverkssegment**.

Det förstärker behovet av att organisationens dokumenterade säkerhetsmodell överensstämmer med verkligheten.

Om exempelvis organisationens policy anger att administrativa konton skyddas med MFA, att nätverk är segmenterade eller att säkerhetsloggning sker, behöver detta också kunna verifieras tekniskt.

8. Säkerhetsskanning

Säkerhetsskanning är ett separat tillsynsverktyg.

Syftet är att bedöma **effektiviteten hos genomförda säkerhetsåtgärder i organisationens digitala miljö**.

Skanningen kan bland annat identifiera:

- sårbarheter,
- osäkra konfigurationer,
- tekniska brister.

Tillsynsmyndigheten utför skanningen men kan anlita en extern aktör för genomförandet.

9. Riskbaserat urval

Tillsynsmyndigheten ska använda en **riskbaserad metod** för att välja:

- vilken verksamhetsutövare som ska skannas,
- vilka system som ska skannas,
- vilka metoder som ska användas.

Vid val av system bör bland annat följande beaktas:

- om systemet är sektorskritiskt,
- integrationer och beroenden,
- tidigare incidenter,

- rapporterade sårbarheter,
- exponering mot internet,
- systemets tekniska riskprofil.

Det innebär att organisationens mest kritiska och exponerade system sannolikt också är de system som är mest relevanta ur ett tillsynsperspektiv.

10. Driftpåverkan ska minimeras

Säkerhetsskanning ska genomföras så att negativ påverkan på organisationens system minimeras.

Innan skanning bör tillsynsmyndigheten och verksamhetsutövaren, om inte särskilda skäl talar emot, tillsammans:

1. bedöma risken för driftpåverkan,
2. planera genomförandet för att minimera belastning,
3. ta fram en plan för att avbryta skanningen,
4. bedöma behovet av återställningsförmåga.

Detta är särskilt viktigt för exempelvis OT, samhällskritiska system och andra miljöer där aktiv skanning kan innebära operativa risker.

11. Skanningen begränsas till relevanta system

Säkerhetsskanningen ska endast genomföras i den omfattning som är nödvändig för tillsynen.

Den ska dessutom avse system som verksamhetsutövaren har **rådighet över inom ramen för sin verksamhet**.

Detta är viktigt i moderna hybrid- och molnmiljöer där verksamhetsutövaren inte nödvändigtvis har teknisk rådighet över alla underliggande komponenter.

12. Identifierade sårbarheter rapporteras tillbaka

Om brister eller sårbarheter upptäcks genom säkerhetsskanning ska verksamhetsutövaren informeras **utan dröjsmål** så att åtgärder kan vidtas skyndsamt.

Även vid säkerhetsrevision finns regler för hantering av tidigare opublicerade sårbarheter.

Organisationen behöver därför ha en etablerad process för att snabbt:

ta emot → bedöma → prioritera → åtgärda → verifiera

sårbarheter som identifieras i samband med tillsyn.

Vad innebär MCFFS 2026:12 i praktiken?

Den kanske viktigaste slutsatsen är att NIS2-efterlevnad behöver vara **verifierbar**.

Det räcker inte att organisationen har en policy som säger:

"Privilegierade konton ska skyddas med MFA."

Organisationen behöver kunna visa att detta faktiskt är implementerat.

Samma princip gäller exempelvis:

- nätverkssegmentering,
- loggning,
- patchhantering,
- backup,
- sårbarhetshantering,
- leverantörskontroller,
- incidenthantering,
- kontinuitet,
- utbildning,
- fysisk säkerhet.

MCFFS 2026:12 gör därför begreppet **evidence-based compliance** särskilt relevant för NIS2.

Hur bör organisationen förbereda sig?

Ett bra sätt att förbereda organisationen är att genomföra en intern **NIS2 readiness review** som efterliknar en framtida tillsyn.

1. Dokumentation

Säkerställ att relevanta policies, processer, riskanalyser och beslut finns dokumenterade och är aktuella.

2. Intervjuer

Kontrollera att systemägare, informationsägare, IT-drift, säkerhetsfunktion och ledning faktiskt känner till sina roller och kan beskriva hur processerna fungerar.

3. Teknisk verifiering

Verifiera att dokumenterade säkerhetsåtgärder faktiskt finns implementerade.

Exempel:

Policy: MFA krävs för administratörer. **Evidens:** Konfiguration från identitetsplattformen visar att MFA faktiskt krävs.

Policy: Säkerhetsloggar samlas centralt. **Evidens:** SIEM-plattformen visar att relevanta system skickar loggar.

Policy: Kritiska system säkerhetskopieras. **Evidens:** Backupjobb, återställningstest och resultat kan visas.

4. Sårbarhetsskanning

Genomför regelbunden egen sårbarhetsskanning innan en tillsynsmyndighet gör det.

5. Evidensbibliotek

Överväg att skapa ett strukturerat **NIS2 Evidence Repository** där organisationen samlar dokumentation och tekniska bevis kopplade till respektive krav.

Exempel på evidens att förbereda

Område	Exempel på evidens
Governance	Ledningsbeslut, ansvarsfördelning, styrande dokument
Risk	Riskregister, riskanalyser, åtgärdsplaner
Informationsklassning	Klassningsmodell och genomförda klassningar
IAM	Behörighetsmodeller, MFA-konfiguration, access reviews
Privilegier	PAM/PIM-konfiguration och administrativa konton
Asset Management	System-, hårdvaru- och mjukvaruinventering
Network Security	Nätverksdiagram, segmentering och brandväggsregler
Logging	SIEM-konfiguration, loggkällor och retention
Vulnerability Management	Scanresultat och remediation
Patch Management	Patchstatus, SLA och avvikelser
Incident Management	Incidentplaner, ärenden och övningsresultat
Continuity	BCP/DR-planer och genomförda tester
Backup	Backupkonfiguration och restore-tester
Supplier Security	Avtal, säkerhetskrav och leverantörsbedömningar
Training	Utbildningsregister och genomförda övningar
Physical Security	Tillträdeskontroller och rutiner
Assurance	Internrevisioner, penetrationstester och uppföljningar

Från policybaserad till evidensbaserad compliance

MCFFS 2026:12 visar tydligt vilken riktning den svenska NIS2-tillsynen kan ta.

Tillsyn kan innebära:

Dokumentgranskning → intervjuer → teknisk verifiering → kontroll på plats → säkerhetsskanning.

Organisationer bör därför redan nu börja arbeta enligt samma princip.

Den centrala frågan för varje NIS2-krav bör vara:

”Vilken evidens kan vi presentera för att visa att detta krav faktiskt är uppfyllt?”

Det är ett betydligt starkare utgångsläge inför framtida tillsyn än att börja samla bevis först när tillsynsmyndigheten hör av sig.

Läs originalföreskriften

[NCSC/FRA – MCFFS 2026:12](#)